

Technical Threat Intelligence Analysis of Triton Safety Instrumented System Attack (C0030) :-

- MITRE ATT&CK Campaign and Software Intelligence Report
- Prepared By Intern ID: 2130
- Program: MITRE Group Leader Selection Program
- Topic: Campaign C0030 and Software S0300 – S0310

1.Introduction :-

Cyber Threat Intelligence (CTI) plays an important role in identifying, analyzing, and mitigating cyber threats targeting organizations and critical infrastructure. This report presents a technical analysis of the MITRE ATT&CK campaign C0030, known as the Triton Safety Instrumented System Attack, along with software entries S0300–S0310.

The report focuses on:

- Threat actor behavior
- Industrial Control System (ICS) attack
- MITRE ATT&CK techniques
- Malware operations
- Indicators of Compromise (IoCs)
- Detection and mitigation strategies

The objective of this report is to demonstrate practical cyber threat intelligence research, malware analysis, and ATT&CK framework mapping.

2.Campaign C0030 Overview :-

CAMPAIGN OVERVIEW
C0030 — Triton Safety Instrumented System Attack

C0030 Campaign ID	2017 Year Discovered	OT/ICS Target Sector	CRITICAL Severity
----------------------	-------------------------	-------------------------	----------------------

Campaign Summary

The Triton campaign targeted Safety Instrumented Systems (SIS) at a Middle Eastern petrochemical facility. Attackers deployed the Triton malware framework against Schneider Electric Triconex controllers, attempting to disable safety mechanisms that prevent physical disasters.

This campaign is considered unprecedented — It was the first publicly confirmed attack designed to cause physical harm by sabotaging industrial safety systems responsible for preventing explosions and equipment damage.

Attack Objectives

- Compromise petrochemical facility ICS
- Disable safety shutdown mechanisms
- Manipulate Triconex SIS controllers
- Enable catastrophic physical damage
- Establish persistent OT network access

- Name : - Triton Safety Instrumented System Attack
- Campaign ID :- C0030

Overview : - The Triton campaign targeted industrial safety systems within critical infrastructure environments. The attackers focused on compromising Safety Instrumented Systems (SIS) used in petrochemical facilities. The attack involved deploying Triton malware against Schneider Electric Triconex controllers.

The campaign is considered one of the most advanced industrial cyberattacks ever discovered because it attempted to manipulate safety mechanisms designed to prevent physical damage and loss of life

Primary Targets : -

- Petrochemical organizations
- Industrial Control Systems (ICS)
- Operational Technology (OT) environments
- Safety Instrumented Systems (SIS)

Objectives of Attack : -

- Gain unauthorized access to industrial networks
- Manipulate safety controllers
- Disrupt industrial operations
- Potentially cause physical damage

3. Threat Actor Profile – TEMP.Veles

- Threat Group - TEMP.Veles (also known as XENOTIME)
- Threat Actor Type - State-sponsored industrial threat actor

Characteristics :-

- Advanced operational capabilities
- Focus on industrial infrastructure
- Uses customized malware
- Conducts stealthy lateral movement
- Employs credential theft and remote access techniques

Known Activities :-

- ICS targeting
- SIS manipulation
- Malware deployment
- Credential harvesting
- Network reconnaissance

Associated Malware :-

- Triton / TRISIS / HatMan
- Cobalt Strike
- PowerShell payloads

THREAT ACTOR PROFILE

TEMP.Veles (XENOTIME) — State-Sponsored ICS Threat Group



TEMP.Veles
a.k.a. XENOTIME

Nation-State Actor

ICS / OT Specialist

APT Classification

Attribution & Origin

Attribution
Russian origin (Mandiant/FireEye, 2018)

Linked Org
Central Scientific Research Institute of Chemistry and Mechanics (CNIIMH)

Activity Since
~2013 (ICS focus from ~2014)

Motivation
Espionage & sabotage of energy sector

Malware
Triton / TRISIS / HatMan

C2 Tools
Cobalt Strike, custom PowerShell

Known Capabilities

OT Protocol Expertise
Deep knowledge of Triconex TriStation protocol

Custom ICS Malware
Developed Triton framework specifically for SIS

Long-term Persistence
Months of undetected dwell time in OT network

Credential Harvesting
LSASS dumping, Mimikatz, Pass-the-Hash

Living Off the Land
LOLBins, PSEXEC, native admin tools

4. Attack Timeline :-

Year/Date	Event
2014 (est.)	TEMP.VELAS gains initial foothold on the target's corporate IT network. Dragos assessed the group had been inside the network since at least 2014.
June 2017	First deployment of TRITON malware against the facility's Safety Instrumented System (SIS) controllers.
August 2017	Second TRITON deployment. The malware contains a logic flaw that inadvertently triggers a safety trip, causing an unplanned plant shutdown. This is the event that exposes the intrusion.
Aug-Sep 2017	Incident response initiated. FireEye Mandiant and other firms are engaged. The malware is analyzed and named TRITON / TRISIS / HatMan.
December 2017	FireEye publicly discloses the campaign and attributes it to a state-sponsored actor. The petrochemical facility is widely believed to be Tasnee in Saudi Arabia.
October 2018	FireEye attributes TRITON to TsNIIKhM — a Russian government-controlled research institution — with high confidence.
March 2019	FireEye discloses that a second critical infrastructure organization has been compromised using the same TRITON toolset.
October 2020	U.S. Treasury (OFAC) formally sanctions TsNIIKhM under CAATSA Section 224.
March 2022	U.S. DOJ unseals indictment of Evgeny Viktorovich Gladkikh for his role in the attack. FBI issues a warning that TEMP.Veles continues to target the global energy sector.

5. Objectives of the Attack

The primary objective of the Triton campaign was not data theft or financial gain — it was physical sabotage. The attackers aimed to:

- Disable or manipulate Triconex SIS controllers to remove their ability to trigger emergency shutdowns.
- Enable unsafe plant conditions — potentially causing explosions, fires, toxic gas releases, or equipment destruction.
- Gain persistent, undetected access to both the IT and OT networks of a critical industrial facility.
- Test and validate the TRITON framework in a live environment for potential future deployment against other targets.

The attackers did not appear to conduct typical espionage activities such as keylogging or data exfiltration. Their singular focus was OT network access and SIS manipulation, indicating a long-term strategic sabotage mission rather than intelligence collection.

6. Targeted Sector / Countries

Primary Target Country	Saudi Arabia (facility widely attributed to Tasnee – National Industrialization Co.)
Sector	Petrochemical / Oil & Gas / Critical Infrastructure
Target Technology	Schneider Electric Triconex Safety Instrumented System (SIS) Controllers — specific firmware versions
Broader Targeting (post-2017)	Dragos (XENOTIME) identified approximately 12 companies with TEMP.Veles-related early-stage compromise activity globally, including in North America and Europe.

7. Attack Flow



8. MITRE ATT&CK Techniques Used

The following table maps documented adversary behaviors to ATT&CK techniques across both Enterprise and ICS domains:

Technique ID	Tactic	Name	Description / Procedure
T1566	Initial Access	Phishing	Spear-phishing used for initial IT network access against facility personnel.
T1078	Credential Access / Persistence	Valid Accounts	Compromised legitimate credentials used for IT and OT network access and persistence.

T1003	Credential Access	OS Credential Dumping	Mimikatz and SecHack used to extract credentials from compromised systems.
T1046	Discovery	Network Service Scanning	Reconnaissance conducted against IT and OT network targets to map environment.
T1082	Discovery	System Information Discovery	Adversary profiled target systems including engineering workstations.
T1021.001	Lateral Movement	Remote Desktop Protocol	RDP used to move laterally within the corporate and OT networks.
T1036	Defense Evasion	Masquerading	Custom attack tools designed to mimic legitimate software to evade detection.
T1053	Persistence	Scheduled Task/Job	Scheduled tasks used to maintain persistent access to compromised systems.
T1105	Command & Control	Ingress Tool Transfer	TRITON framework and supporting tools transferred to the SIS engineering workstation.
T0817 (ICS)	Initial Access (ICS)	Drive-by Compromise	Lateral pivot from IT into ICS/OT network leveraging trust relationships.
T0821 (ICS)	Lateral Movement (ICS)	Modify Controller Tasking	TRITON directly modified Triconex SIS controller logic via TriStation protocol.
T0831 (ICS)	Inhibit Response Function	Manipulation of Control	Safety system reprogrammed to inhibit its ability to trigger emergency shutdowns.
T0816 (ICS)	Impact	Device Restart/Shutdown	Safety logic modification caused inadvertent SIS safety trip and plant shutdown.

8. Real-World Incidents

Incident 1 – Primary Petrochemical Attack (2017)

- Location: Saudi Arabia — believed to be a Tasnee-owned facility in Al Jubail.
- In August 2017, TRITON malware caused an unplanned safety trip at the facility during its second deployment.
- The incident halted plant operations and triggered forensic investigation. The malware was discovered on the SIS Engineering Workstation.
- No casualties were reported; however, security experts noted that a successful SIS disablement could have caused an explosion or toxic release.

Incident 2 – Second Victim (2019)

- In March 2019, FireEye disclosed that TEMP.Veles had successfully compromised a second critical infrastructure organization with TRITON tooling.
- The second victim was identified while still actively compromised — attackers were inside the corporate IT network at the time of discovery.
- The second incident demonstrated that TRITON was not a one-off attack but an ongoing capability and campaign.

Broader Activity – XENOTIME Tracking

- Dragos (tracking as XENOTIME) identified approximately 12 organizations globally with early-stage TEMP.Veles-related compromise activity, including targets in North America and Australia.
- The FBI issued a formal warning in March 2022 that TsNIIKhM-linked activity continues to target the global energy sector.

9. Detection Opportunities

IT Network Detections

- Anomalous credential usage: Monitor for Valid Account (T1078) abuse — logins from unusual times, locations, or systems, especially on OT-adjacent systems.
- Credential dumping tools: Deploy EDR solutions capable of detecting Mimikatz signatures and LSASS memory access (T1003.001).
- Lateral movement via RDP: Alert on RDP (T1021.001) connections to engineering workstations or historian servers from non-standard source IPs.
- Masquerading: Monitor for processes with names matching legitimate tools but executing from unexpected directories or with unusual parent processes (T1036).

OT / ICS Network Detections

- TriStation protocol monitoring: Inspect industrial network traffic for anomalous TriStation protocol messages — any write commands to SIS from non-engineering sources should trigger alerts.
- SIS configuration changes: Implement file integrity monitoring and change detection on the SIS Engineering Workstation. Any unauthorized modification to SIS logic should be treated as a critical incident.
- Unexpected process execution on EWS: Monitor for scripting interpreter execution (T1059) or new binary execution on the Engineering Workstation.
- OT network anomalies: Deploy ICS-aware network monitoring tools (e.g., Claroty, Dragos Platform, Nozomi Networks) to detect protocol anomalies and unexpected communication paths.

Behavioral / Threat Hunting

- Hunt for long-dwell indicators: Review authentication logs for accounts with consistent low-frequency access over multi-year periods — TEMP.Veles maintained presence for 1–3 years before SIS access.
- Scheduled task auditing: Regularly audit scheduled tasks across IT and OT systems for unauthorized or obfuscated entries (T1053).
- Cross-network communication: Monitor for any IT-to-OT communication that bypasses established firewall rules or demilitarized zone (DMZ) architectures.

10. Defensive Recommendations

Network Architecture

- Enforce strict IT/OT network segmentation with hardware-enforced demilitarized zones (DMZs). No direct communication path should exist between corporate IT and SIS networks.
- Implement unidirectional security gateways (data diodes) for any required data flow from OT to IT.
- Restrict all external internet access from OT environments.

Identity & Access Management

Enforce Multi-Factor Authentication (MFA) on all accounts — especially those with access to engineering workstations and OT systems (mitigates T1078).

- Apply the principle of least privilege: restrict SIS EWS access to only designated ICS engineers.
- Audit and rotate credentials regularly; monitor for anomalous account behavior.

Endpoint & OT Security

- Deploy application whitelisting on engineering workstations to prevent execution of unauthorized binaries (mitigates T1059, T1036).
- Enable and monitor Windows Event Logs, Sysmon, and PowerShell script block logging on all IT-connected OT support systems.
- Conduct regular integrity checks on SIS controller firmware and logic configurations.

Incident Response & Resilience

- Develop and exercise an ICS-specific Incident Response (IR) plan that includes SIS compromise scenarios.
- Maintain offline backups of SIS configurations and verified-clean firmware images.
- Establish a process for verifying SIS integrity before plant restart following any unplanned safety trip.
- Subscribe to ICS-CERT / CISA advisories and apply vendor patches promptly — particularly Schneider Electric Triconex firmware updates.

Threat Intelligence

- Monitor U.S. CISA, FBI, and sector-specific ISACs (E-ISAC, ONG-ISAC) for TEMP.Veles / XENOTIME indicators.
- Use the MITRE ATT&CK for ICS matrix to assess coverage gaps in detection and response capabilities.
- Engage ICS-specialized security vendors (Dragos, Claroty, Nozomi) for OT-specific threat detection

11. References & Sources All references are official or authoritative sources:

- MITRE ATT&CK – Campaign C0030: <https://attack.mitre.org/campaigns/C0030/>
- MITRE ATT&CK – TEMP.Veles Group G0088: <https://attack.mitre.org/groups/G0088/>
- FireEye / Mandiant (2017): 'Attackers Deploy New ICS Attack Framework TRITON and Cause Operational Disruption to Critical Infrastructure.'
- FireEye / Mandiant (2018): 'TRITON Attribution: Russian Government-Owned Lab Most Likely Built Custom Intrusion Tools for TRITON Attackers.'
- FireEye / Mandiant (2019): 'TRITON Actor TTP Profile, Custom Attack Tools, Detections, and ATT&CK Mapping.' Google Cloud Blog.
- U.S. Department of Treasury OFAC (2020): 'Treasury Sanctions Russian Government Research Institution Connected to the Triton Malware.'
- FBI PIN (2022): 'TRITON Malware Remains Threat to Global Critical Infrastructure Industrial Control Systems.'
- Dragos (2019): XENOTIME Threat Group Intelligence Report.
- MIT Technology Review (2019): 'Triton is the world's most murderous malware, and it's spreading.'
- CISA ICS Advisory: Schneider Electric Triconex Tricon (Update B).
- CISA Malware Analysis Report: HatMan – Safety System Targeted Malware (Update B).

MITRE ATT&CK RESEARCH

SOFTWARE RESEARCH REPORT

Software Range S0300 – S0309 | Android Mobile Malware

Intern ID	2130
Assigned Campaign	Campaign No. 30 (C0030)
Software Range	S0300 – S0309 (10 Entries)
Platform Domain	MITRE ATT&CK Mobile

1. Software Entries Index – S0300 to S0309

Num	ATT&CK ID	Name	Type	Platform/Notes
1	S0300	DressCode	Malware – Network Tunneling / Proxy Trojan	Android Mobile MITRE ATT&CK Mobile Domain
2	S0301	Dendroid	Malware – Android Remote Access Trojan (RAT)	Android Mobile MITRE ATT&CK Mobile Domain
3	S0302	Twitoor	Malware – Android Dropper / Botnet	Android Mobile MITRE ATT&CK Mobile Domain
4	S0303	MazarBOT	Malware – Android Banking Trojan / SMS Malware	Android Mobile MITRE ATT&CK Mobile Domain
5	S0304	Android/Chuli.A	Malware – Android Spyware / Surveillance Tool	Android Mobile MITRE ATT&CK Mobile Domain
6	S0305	SpyNote RAT	Malware – Android Remote Access Trojan (RAT)	Android Mobile MITRE ATT&CK Mobile Domain
7	S0306	Trojan-SMS.Android.OS.FakeInst.a	Malware – Android SMS Trojan	Android Mobile MITRE ATT&CK Mobile Domain
8	S0307	Trojan-SMS.Android.OS.Agent.ao	Malware – Android SMS Trojan	Android Mobile MITRE ATT&CK Mobile Domain
9	S0308	Trojan-SMS.Android.OS.OpFake.a	Malware – Android SMS Trojan	Android Mobile MITRE ATT&CK Mobile Domain
10	S0309	Adups	Malware – Android Pre-installed Spyware / Supply Chain Compromise	Android Mobile MITRE ATT&CK Mobile Domain

Software Entry 1 of 10 — S0300: DressCode

1. Name & Type / Basic Information

ATT&CK ID	S0300
Type	Malware – Network Tunneling / Proxy Trojan
Platform	Android (Mobile)
First Seen	August 2016
Last Modified (MITRE)	25 April 2025
Threat Actor	No specific APT attribution; financially/espionage motivated unknown actors
Associated Names	DressCode Android Malware Family

2. Description

DressCode is an Android malware family first discovered in August 2016 by Check Point researchers, and later analyzed in depth by Trend Micro. It was distributed through over 3,000 trojanized Android applications, including more than 400 hosted on Google Play. Unlike traditional spyware, DressCode's primary function is to establish a SOCKS proxy tunnel on the infected device, effectively turning the handset into a relay node. This makes it particularly dangerous in BYOD (Bring Your Own Device) enterprise environments, where an infected personal device connected to a corporate Wi-Fi network can give attackers a bridge into internal enterprise infrastructure — bypassing network address translation (NAT) and firewall controls.

3. ATT&CK Techniques Used

Technique	Tactic	Name	Description/Use
T1428	Network Exploitation	Exploitation of Remote Services	DressCode sets up a SOCKS proxy tunnel to compromise enterprise networks that the mobile device is connected to, allowing traffic relay from attacker to internal servers.

4. Execution Method

DressCode is executed after the user installs a trojanized legitimate-looking Android application from Google Play or third-party app stores. Upon launch, it silently establishes a SOCKS proxy connection to an attacker-controlled C2 server without user interaction or visible indicators.

5. Persistence Techniques

Persistence is achieved through Android application auto-start mechanisms. The malware registers Android broadcast receivers that trigger on device boot events (BOOT_COMPLETED), ensuring the SOCKS tunnel is re-established automatically after restart.

6. Privilege Escalation

No explicit privilege escalation documented. DressCode operates within normal Android app permissions but leverages network access permissions to establish its tunnel. Root access is not required.

7. Defense Evasion

DressCode disguised itself within thousands of legitimate-looking applications (games, performance tools, customization apps). The malicious code was embedded inside otherwise functional apps to evade both user suspicion and automated app store review processes (Google Bouncer). The SOCKS proxy behavior mimics legitimate network activity.

8. Credential Access

DressCode itself does not directly harvest credentials. However, the SOCKS tunnel it establishes enables adversaries to conduct credential attacks against internal enterprise systems through the infected device as a relay.

9. Discovery Techniques

No direct discovery techniques documented on device. The tunnel capability allows attackers to conduct their own network reconnaissance against internal enterprise infrastructure via the relay.

10. Lateral Movement

Lateral movement is a core threat: once the SOCKS tunnel is live, attackers can pivot from the mobile device into the enterprise network, attacking internal servers, databases, and services that are inaccessible from the internet.

11. Command & Control (C2)

DressCode communicates with a remote attacker-controlled C2 server via a SOCKS proxy protocol tunnel. The C2 connection is established at first execution and maintained persistently. Traffic is routed through the infected mobile device.

12. Exfiltration

DressCode functions primarily as an access/tunneling tool. While it does not directly exfiltrate device data, the tunnel it creates enables downstream data exfiltration from enterprise networks through the infected device.

13. Impact Analysis

Critical risk in BYOD enterprise environments. An infected personal device connected to corporate Wi-Fi becomes a persistent backdoor into the internal network, enabling adversaries to attack internal servers, exfiltrate data, and pivot laterally — all without the corporate perimeter defenses detecting the source.

14. Indicators of Compromise (IOCs)

- Presence of apps requesting unusual network permissions (INTERNET + ACCESS_NETWORK_STATE) without legitimate need
- Unexpected outbound SOCKS proxy traffic from mobile devices
- Known malicious C2 IPs associated with DressCode: 31.184.234[.]0/24 range (Trend Micro reported)
- Trojanized APK package names mimicking legitimate apps (e.g., com.game.*, com.util.*) with embedded SOCKS code
- Anomalous persistent background network connections from mobile apps after screen-off

15. Detection & Mitigation

- Deploy Mobile Device Management (MDM) solutions to monitor and restrict app installations to vetted sources only.
- Implement network-level monitoring for unexpected SOCKS proxy traffic originating from mobile devices.
- Use Google Play Protect and reputable mobile AV solutions (e.g., Lookout, Zimperium zIPS) capable of detecting DressCode variants.
- Enforce network segmentation — personal/BYOD devices should connect to a separate VLAN with no access to internal enterprise resources.
- Monitor Android device network activity for persistent outbound connections on non-standard ports from installed applications.
- Mitigation M1006 (Use Recent OS Version) and M1011 (User Guidance) apply per MITRE ATT&CK Mobile mitigations.

16. References & Sources

- MITRE ATT&CK – S0300 DressCode: <https://attack.mitre.org/software/S0300/>
- Echo Duan, Trend Micro (2016): DressCode and its Potential Impact for Enterprises.
- Check Point Research (2016): DressCode Android Malware in Google Play.
- CyberScoop (2016): DressCode Android malware shows BYOD danger.

Software Entry 2 of 10 – S0301: Dendroid

1. Name & Type / Basic Information

ATT&CK ID	S0301
Type	Malware – Android Remote Access Trojan (RAT)
Platform	Android (Mobile)
First Seen	March 2014
Last Modified (MITRE)	25 April 2025
Threat Actor	Crimeware – sold on underground forums by actor 'Soccer'; no specific APT attribution; source code leaked Aug 2014
Associated Names	Android.Dendroid (Symantec)

2. Description

Dendroid is a fully featured commercial Android Remote Access Trojan (RAT) that was first reported in March 2014. It was sold on underground forums for a one-time fee of \$300 by a seller known as 'Soccer', and included a PHP-based web administration panel, an APK binder tool to inject the RAT into legitimate apps, and 24/7 support. Dendroid is built on an HTTP-based C2 architecture and provides extensive device control capabilities including audio recording, video capture, SMS interception, call logging, and browser history theft. Its APK binder capability made it trivial for low-skill threat actors to trojanize existing legitimate apps and redistribute them. In August 2014, Dendroid's full source code was leaked on GitHub, further democratizing its use and spawning variants.

3. ATT&CK Techniques Used

Technique ID	Tactic	Name	Description/Use
T1429	Collection	Audio Capture	Can record audio and outgoing phone calls.
T1512	Collection	Video Capture	Can take photos and record videos from the device camera.
T1533	Collection	Data from Local System	Collects photos, browser history, bookmarks, and stored device accounts.
T1636.004	Collection	Protected User Data: SMS Messages	Intercepts and exfiltrates SMS messages.
T1582	Impact	SMS Control	Can send and block SMS messages on behalf of the attacker.
T1417.002	Credential Access	Input Capture: GUI Input Capture	Opens fake dialog boxes to trick users into entering passwords.
T1655.001	Defense Evasion	Masquerading: Match Legitimate Name	Can be bound into legitimate apps prior to installation.
T1633.001	Defense Evasion	Virtualization/Sandbox Evasion	Detects if running in an Android emulator to avoid analysis.

4. Execution Method

Dendroid is deployed via a trojanized APK — a legitimate application repackaged with the Dendroid payload using the bundled APK Binder tool. The victim installs the app from third-party stores or phishing links. Upon launch, the RAT silently activates and connects to the attacker's PHP control panel over HTTP.

5. Persistence Techniques

Dendroid leverages Android broadcast receivers registered for `BOOT_COMPLETED` intent, ensuring the RAT re-activates after every device reboot. It also includes auto-update functionality via the C2 panel to push newer versions.

6. Privilege Escalation

Dendroid does not typically require root access. It abuses Android's permission model — requesting broad permissions at install time (RECORD_AUDIO, CAMERA, READ_SMS, READ_CONTACTS) which users often grant without scrutiny.

7. Defense Evasion

Primary evasion method is masquerading within legitimate repackaged apps (T1655.001). Additionally, Dendroid includes a 'GPlayBypass' flag designed to evade Google Play's Bouncer sandboxing tool. It also detects emulator environments (T1633.001) to hinder dynamic analysis.

8. Credential Access

Dendroid intercepts SMS-based 2FA codes, reads stored account data from the device, and can open fake GUI dialog boxes (T1417.002) to trick users into entering credentials, which are then transmitted to the C2 server.

9. Discovery Techniques

Dendroid collects comprehensive device information including installed applications, browser history, bookmarks, user accounts, and stored contacts — enabling the attacker to profile the victim and identify high-value targets or additional attack vectors.

10. Lateral Movement

No direct lateral movement capability documented. However, the ability to intercept 2FA SMS messages and harvest credentials enables account takeover that could facilitate access to corporate systems.

11. Command & Control (C2)

Dendroid uses an HTTP-based C2 protocol communicating with a PHP web panel. Commands are issued via the panel, and the bot responds with collected data. All communication occurs over standard HTTP to blend with legitimate traffic.

12. Exfiltration

Dendroid exfiltrates collected data (SMS, call logs, photos, videos, contacts, browser history, audio recordings) to the attacker's C2 server via HTTP POST requests.

13. Impact Analysis

Full device compromise: surveillance capability (audio, video, location), credential theft via SMS and fake UI, call log manipulation, SMS fraud capability, and ability to conduct HTTP flood DoS attacks. Source code leak means variants continue to circulate.

14. Indicators of Compromise (IOCs)

- APK package names: common pattern of legitimate app names with embedded secondary .dex payload
- HTTP connections to PHP-based panel endpoints (e.g., /panel/gate.php, /panel/connect.php)
- Unusual permission combinations: RECORD_AUDIO + CAMERA + READ_SMS + READ_CALL_LOG + INTERNET requested by non-utility apps
- Detection: Android.Dendroid (Symantec), Backdoor.AndroidOS.Dendroid (Kaspersky)SHA256 samples documented by SonicWALL Threats Research Team (2014 source code analysis)
- Broadcast receiver: android.intent.action.BOOT_COMPLETED registered by non-system apps

15. Detection & Mitigation

- Use mobile EDR/AV solutions with signatures for Dendroid variants (Lookout, Zimperium, Kaspersky Mobile).
- Block sideloading of APKs from unknown sources via MDM policy.
- Monitor for HTTP POST traffic to PHP panels from mobile devices — especially to endpoints like /gate.php.
- Flag apps requesting READ_SMS + RECORD_AUDIO + CAMERA simultaneously at install time.
- Perform static and dynamic APK analysis on enterprise-distributed apps using tools like MobSF or VirusTotal.
- Apply MITRE Mobile mitigation M1012 (Enterprise Policy) to prevent installation of unapproved apps.

16. References & Sources

- MITRE ATT&CK – S0301 Dendroid: <https://attack.mitre.org/software/S0301/>
- Marc Rogers, Lookout (2014): Dendroid malware can take over your camera, record audio.
- Symantec/SecurityWeek (2014): Dendroid RAT – the Next Stage of Android Malware Evolution.
- Dark Reading (2014): Dissecting Dendroid – An In-Depth Look Inside an Android RAT Kit.
- SonicWALL Threats Research Team (2014): Source Code Leaks for Android RAT Dendroid.

Software Entry 3 of 10 — S0302: Twitoor

1. Name & Type / Basic Information

ATT&CK ID	S0302
Type	Malware – Android Dropper / Botnet
Platform	Android (Mobile)
First Seen	August 2016
Last Modified (MITRE)	25 April 2025
Threat Actor	Unknown; first Twitter-controlled Android botnet discovered – no APT attribution
Associated Names	First Twitter-controlled Android botnet (ESET)

2. Description

Twitoor is a notable Android malware dropper that achieved the distinction of being the first documented Android botnet to use Twitter as its Command and Control (C2) channel. Discovered by ESET in August 2016, Twitoor does not deliver its payload directly — instead, it polls attacker-controlled Twitter accounts for encoded commands, including instructions to download and install additional malware. This social-media-based C2 mechanism makes traditional network-layer C2 blocking ineffective, as Twitter traffic is expected and allowed on most networks. Twitoor also hides its presence by suppressing its icon from the Android application launcher.

3. ATT&CK Techniques Used

Technique	Tactic	Name	Description/Use
T1481.003	Command & Control	Web Service: One-Way Communication	Controlled via attacker Twitter accounts, polling them for encoded commands.
T1521	Command & Control	Encrypted Channel	Encrypts its C2 communication with the Twitter channel.
T1628.001	Defense Evasion	Hide Artifacts: Suppress Application Icon	Suppresses its launcher icon to hide presence from the user.

4. Execution Method

Twitoor is distributed as a trojanized APK disguised as an MMS application or pornographic content player. Once installed, it silently polls a designated Twitter account at intervals for base64-encoded commands. It does not present a visible UI. Commands instruct it to download and silently install further malware payloads.

5. Persistence Techniques

Twitoor uses Android broadcast receiver BOOT_COMPLETED to ensure it restarts after device reboot. Its icon suppression (T1628.001) prevents the user from easily identifying or uninstalling it.

6. Privilege Escalation

No explicit privilege escalation. Twitoor operates within normal Android permissions. Its dropper functionality allows it to install payloads that may themselves seek elevated privileges.

7. Defense Evasion

Key evasion technique is use of legitimate social media (Twitter) as C2 (T1481.003), which bypasses network-based C2 detection. Icon suppression (T1628.001) hides the app from the launcher. Encrypted communication (T1521) prevents payload inspection.

8. Credential Access

Twitoor itself does not harvest credentials. However, as a dropper, it installs secondary malware payloads that may include banking trojans or stealers capable of credential access.

9. Discovery Techniques

No direct discovery techniques documented. Twitoor's primary role is as a delivery mechanism — it downloads and installs other malware whose capabilities may include device profiling.

10. Lateral Movement

No direct lateral movement. Secondary payloads delivered by Twitoor may include banking malware or RATs capable of facilitating broader compromise.

11. Command & Control (C2)

Unique C2 mechanism: Twitoor polls attacker-controlled Twitter accounts for base64-encoded commands. Commands are embedded in tweets. The C2 channel can be quickly rotated by the attacker simply by switching to a new Twitter account — making takedown difficult. All communication is encrypted (T1521).

12. Exfiltration

Twitoor itself does not exfiltrate device data. The malware payloads it drops may perform exfiltration based on their own capabilities.

13. Impact Analysis

As a dropper and botnet node, Twitoor's impact is determined by the payloads it installs. Documented payloads include mobile banking trojans. The Twitter C2 mechanism is highly resilient and difficult to block without blocking Twitter platform-wide. The icon suppression means infected devices may go undetected indefinitely.

14. Indicators of Compromise (IOCs)

APK disguised as MMS application or adult media player

- Outbound connections to Twitter API endpoints from non-Twitter apps (anomalous for a background process)
- Detection: Android/Twitoor.A (ESET), Twitter-controlled botnet signatures
- BOOT_COMPLETED broadcast receiver in non-system apps without visible launcher icon
- Encoded (base64) strings in app resources referencing Twitter account handles
- Silent background APK installation activity without user prompt

15. Detection & Mitigation

- Monitor for unexpected Twitter API calls originating from non-Twitter background processes on Android devices.

- Deploy mobile threat detection solutions capable of detecting dropper behavior (silent APK installation).
- Block sideloading via MDM: Twitoor is not distributed through Google Play.
- Use behavioral analysis tools (e.g., MobSF dynamic analysis) to detect Twitter-polling behavior during APK review.
- Flag applications with no visible launcher icon that register BOOT_COMPLETED receivers.
- Apply MITRE Mobile mitigation M1011 (User Guidance) — educate users not to install MMS or media apps from untrusted links.

16. References & Sources

- MITRE ATT&CK – S0302 Twitoor: <https://attack.mitre.org/software/S0302/>
- ESET (2016, August 24): First Twitter-controlled Android botnet discovered. WeLiveSecurity.

• Software Entry 4 of 10 — S0303: MazarBOT

1. Name & Type / Basic Information

ATT&CK ID	S0303
Type	Malware – Android Banking Trojan / SMS Malware
Platform	Android (Mobile)
First Seen	February 2016 (active distribution, Denmark)
Last Modified (MITRE)	25 April 2025
Threat Actor	Unknown; Eastern European cybercriminal group suspected; distributed via SMS phishing campaign
Associated Names	MazarBOT Android Banking Malware

2. Description

MazarBOT is Android malware that was distributed via unsolicited SMS messages in Denmark in 2016, making it one of the first large-scale SMS-based Android malware distribution

campaigns in Western Europe. When the victim opened the malicious link in the SMS, they were prompted to install an APK. Once active, MazarBOT targeted mobile banking applications, intercepting two-factor authentication (2FA) SMS codes to facilitate fraudulent banking transactions. It could also send messages to premium-rate numbers for financial gain and read all incoming SMS communications.

3. ATT&CK Techniques Used

Technique ID	Tactic	Name	Description
T1636.004	Collection	Protected User Data: SMS Messages	Intercepts 2FA codes sent by online banking apps and reads all incoming SMS messages.
T1643	Impact	Generate Traffic from Victim	Sends messages to premium-rate phone numbers, generating fraudulent charges on the victim's account.

4. Execution Method

MazarBOT was distributed via SMS phishing (smishing) campaigns. Victims received a text message claiming to contain a multimedia message (MMS), with a link to an APK. The victim had to manually install the APK, requiring 'Unknown Sources' to be enabled. Upon installation, it requested device administrator and accessibility permissions.

5. Persistence Techniques

MazarBOT requests Device Administrator privileges, making it significantly harder to uninstall through normal means. Removal requires revoking device admin status first, which many users are unaware of. It also uses broadcast receivers for boot persistence.

6. Privilege Escalation

Requests Android Device Administrator status upon installation — a form of privilege escalation on Android, granting the malware elevated control over the device including the ability to resist removal.

7. Defense Evasion

MazarBOT was noted to check the device's language settings and would not install on devices configured in Russian — a common characteristic of Eastern European cybercrime tools to avoid targeting domestic users and law enforcement. This language check acts as a basic evasion mechanism.

8. Credential Access

Intercepts incoming SMS messages (T1636.004) specifically to capture one-time passwords (OTPs) and 2FA codes sent by banking applications, enabling account takeover and fraudulent financial transactions.

9. Discovery Techniques

Limited discovery capability documented. The malware primarily focuses on SMS interception and premium SMS fraud rather than device reconnaissance.

10. Lateral Movement

No direct lateral movement capability. However, the ability to intercept OTPs and 2FA codes enables account takeover of banking and other online services, which could be used to pivot to other accounts.

11. Command & Control (C2)

MazarBOT uses Tor network-based C2 communication to anonymize its traffic and prevent C2 server identification. This makes network-based detection and takedown significantly more difficult.

12. Exfiltration

Exfiltrates intercepted SMS messages (including 2FA codes) and device information to the attacker's C2 infrastructure via Tor. Premium-rate SMS fraud directly transfers funds from the victim's mobile account.

13. Impact Analysis

Direct financial impact via premium-rate SMS fraud. More significantly, 2FA/OTP interception enables complete bypass of mobile banking security controls, allowing fraudulent transactions. Device Administrator persistence makes removal difficult without professional assistance.

14. Indicators of Compromise (IOCs)

- SMS messages containing links to APK downloads (smishing vector) — often mimicking MMS notifications
- APK requesting Device Administrator + READ_SMS + SEND_SMS + accessibility permissions
- Outbound Tor (.onion) network connections from the device
- Device language check behavior — does not execute on Russian-language devices
- Detection: Android.MazarBOT (various AV vendors), identified by Tripwire/Heimdal Security (2016)
- Unsolicited premium-rate SMS charges appearing on victim's bill

15. Detection & Mitigation

- Block installation of APKs from unknown sources via MDM policy.
- Educate users never to install apps linked from SMS messages — this is the sole infection vector.
- Monitor for Tor network traffic (connections to .onion addresses or known Tor exit nodes) from mobile devices.
- Implement mobile banking app fraud detection: alert on OTP delivery followed by immediate account action without user-initiated session.
- Deploy mobile security solutions capable of detecting Device Administrator abuse and unauthorized SMS sending.
- Apply MITRE Mobile mitigation M1011 (User Guidance) and M1006 (Use Recent OS Version).

16. References & Sources

- MITRE ATT&CK – S0303 MazarBOT: <https://attack.mitre.org/software/S0303/>
- Graham Cluley / Tripwire (2016, February): Android users warned of malware attack spreading via SMS.
- Heimdal Security (2016): MazarBOT malware analysis.

Software Entry 5 of 10 — S0304: Android/Chuli.AI

1. Name & Type / Basic Information

ATT&CK ID	S0304
Type	Malware – Android Spyware / Surveillance Tool
Platform	Android (Mobile)
First Seen	March 2013
Last Modified (MITRE)	25 April 2025
Threat Actor	Unknown APT (suspected Chinese state-linked); targeted Tibetan and Uyghur activist groups
Associated Names	Chuli.A, Android Trojan targeted at activists (Kaspersky)

2. Description

Android/Chuli.A is targeted Android spyware that was discovered by Kaspersky Lab in March 2013. It was delivered via a spear-phishing email to Tibetan and Uyghur activist groups, with the malicious APK attached directly to the email. The malware's specific targeting of human rights activists and the sophistication of the delivery method indicates a likely nation-state actor, suspected to be Chinese government-linked. Chuli.A functions as a comprehensive surveillance tool, harvesting location data, contacts, call logs, SMS messages, and device information — transmitting all collected data to a C2 server.

3. ATT&CK Techniques Use

Technique ID	Tactic	Name	Description/Use
T1437.001	Command & Control	Application Layer Protocol: Web Protocols	Uses HTTP uploads to a URL as a C2 mechanism for data exfiltration.
T1430	Collection	Location Tracking	Steals GPS-based geolocation data from the device.
T1644	Command & Control	Out of Band Data	Uses SMS messages to receive C2 commands from the attacker.
T1636.002	Collection	Protected User Data: Call Log	Steals device call logs including caller IDs and timestamps.
T1636.003	Collection	Protected User Data: Contact List	Exfiltrates full contact list from phone and SIM card.
T1636.004	Collection	Protected User Data: SMS Messages	Steals full SMS message content from the device.
T1426	Discovery	System Information Discovery	Gathers phone number, OS version, phone model, and SDK version.

4. Execution Method

Android/Chuli.A was delivered as a malicious APK attached to a targeted spear-phishing email. The email purported to be related to a World Uyghur Congress conference. The victim was socially engineered into installing the attached APK, which presented as a legitimate conference application.

5. Persistence Techniques

Chuli.A registers Android broadcast receivers for `BOOT_COMPLETED` and incoming SMS events, ensuring the malware activates on reboot and can receive C2 commands via SMS at any time.

6. Privilege Escalation

No explicit root exploitation. The malware relies on Android's permission system — requesting broad permissions at install time. It leverages SMS-based C2 which does not require root access.

7. Defense Evasion

Primary evasion is targeted delivery to a very small, specific group (activist community) rather than mass distribution, reducing the likelihood of detection by mainstream security vendors. Masquerading as a conference-related application reduces user suspicion.

8. Credential Access

Chuli.A collects phone-based credentials indirectly through SMS interception (2FA codes), contact data, and call logs which can reveal sensitive communication metadata for activists communicating with at-risk contacts.

9. Discovery Techniques

Collects comprehensive system information (T1426): phone number, OS version, device model, SDK version — allowing the attacker to profile the device and its owner.

10. Lateral Movement

No direct lateral movement. The surveillance data collected (contact lists, call logs) may be used to identify additional targets within the activist community for follow-on spear-phishing campaigns.

11. Command & Control (C2)

Dual C2 mechanism: uses HTTP uploads to a hardcoded URL for data exfiltration (T1437.001), and receives commands via incoming SMS messages (T1644), providing a stealthy out-of-band command channel that does not require an internet connection.

12. Exfiltration

All collected data (location, contacts, call logs, SMS, device info) is exfiltrated via HTTP POST to a C2 server URL. The dual HTTP/SMS C2 architecture provides resilience if one channel is blocked.

13. Impact Analysis

High impact for targeted individuals: complete device surveillance including physical location tracking. For activist communities, exposure of contact lists and communications metadata poses direct personal safety risks. The nation-state targeting nature makes this a significant human rights concern.

14. Indicators of Compromise (IOCs)

- APK delivered via email attachment targeting Tibetan/Uyghur community (spear-phishing vector)
- Malicious C2 domains/IPs identified by Kaspersky in 2013 original analysis
- HTTP POST requests containing base64-encoded device data to hardcoded C2 URLIncoming SMS messages acting as C2 commands (specific number patterns)
- Detection: Android.Chuli.A (Kaspersky), app requesting READ_SMS + READ_CONTACTS + ACCESS_FINE_LOCATION + READ_CALL_LOG
- Package name and certificate fingerprint documented in Kaspersky's 2013 disclosure

15. Detection & Mitigation

Deploy targeted spear-phishing awareness training for high-risk communities (activists, journalists, NGOs).

Never install APKs received via email attachments — use only official app stores.

Use mobile security tools (Lookout Security, Kaspersky Mobile) with APT-aware detection.

- Monitor outbound HTTP POST traffic from Android devices to unusual or hardcoded IP addresses.
- For at-risk individuals: use hardened devices (GrapheneOS, CalyxOS) with minimal app permissions.
- Implement SMS filtering to detect unusual incoming SMS patterns that may represent C2 commands.

16. References & Sources

- MITRE ATT&CK – S0304 Android/Chuli.A: <https://attack.mitre.org/software/S0304/>
- Costin Raiu, Denis Maslennikov, Kurt Baumgartner – Kaspersky (2013): Android Trojan Found in Targeted Attack. Securelist.

Software Entry 6 of 10 — S0305: SpyNote RAT

1. Name & Type / Basic Information

ATT&CK ID	S0305
Type	Malware – Android Remote Access Trojan (RAT)
Platform	Android (Mobile)
First Seen	2016 (original); active through 2025
Last Modified (MITRE)	25 April 2025
Threat Actor	Multiple: OilRig (APT34), APT-C-37 (Pat-Bear), OilAlpha; also crimeware actors; SpyNote.C source code leaked Oct 2022
Associated Names	SpyMax, CypherRAT, CraxsRAT (successor), SpyNote.A/B/C variants

2. Description

SpyNote RAT (Remote Access Trojan) is a sophisticated family of malicious Android applications with a builder tool enabling low-skill actors to create customized RAT variants. Originally emerging around 2016, SpyNote has evolved through multiple versions — SpyNote.A, .B, and .C (also marketed as CypherRAT). In October 2022, the SpyNote.C source code was made public, leading to an explosion of variants. The RAT provides extensive surveillance capabilities including audio/video capture, location tracking, keylogging via Accessibility Services, SMS access, and file exfiltration. It has been used by multiple APT groups (OilRig/APT34, APT-C-37) as well as financially motivated criminals targeting banking sectors.

3. ATT&CK Techniques Used

Technique	Tactic	Name	Description
T1429	Collection	Audio Capture	Activates the device microphone for covert audio recording.
T1512	Collection	Video Capture	Accesses device camera for photo and video capture.
T1533	Collection	Data from Local System	Copies files from device to C2 server.
T1624.001	Persistence	Event Triggered Execution: Broadcast Receivers	Registers broadcast receiver to auto-start on device boot.
T1430	Collection	Location Tracking	Collects GPS-based device location.
T1636.003	Collection	Protected User Data: Contact List	Reads and exfiltrates contact list.
T1636.004	Collection	Protected User Data: SMS Messages	Reads and intercepts SMS messages.
T1418	Discovery	Software Discovery	Enumerates installed applications to identify security tools and high-value apps.
T1406	Defense Evasion	Obfuscated Files or Information	Uses code obfuscation to hinder reverse engineering.

4. Execution Method

SpyNote is distributed via smishing campaigns (malicious SMS links), fake app store pages mimicking Google Play, deceptive websites impersonating legitimate services (Zoom, Skype, Google Meet, antivirus apps), and WhatsApp-delivered APKs. The builder tool allows custom APK generation with configurable C2 settings.

5. Persistence Techniques

Uses Android broadcast receiver for `BOOT_COMPLETED` (T1624.001) to restart on device reboot. Leverages Android Accessibility Services to resist uninstallation — device admin privileges prevent easy removal.

6. Privilege Escalation

Exploits Android Accessibility Services API to gain elevated control over device functions, bypass security restrictions, and prevent uninstallation. Supports rooted devices via SuperSU to achieve full root-level access. Device Administrator enrollment further resists removal.

7. Defense Evasion

Dynamic payload decryption (malicious code decrypted only at runtime to evade static analysis), DEX element injection (malicious code injected into legitimate Android executables), C2 logic obfuscation (T1406), and code obfuscation throughout. Emulator detection prevents analysis in sandboxes.

8. Credential Access

Keylogging via Accessibility Services API captures credentials entered into any app including banking apps. Credential harvesting includes cryptocurrency wallet information and banking app credentials. SMS capture enables 2FA bypass.

9. Discovery Techniques

Enumerates all installed applications (T1418) to identify security software, banking apps, and high-value targets. Collects device info including IMEI, OS version, phone model to detect sandbox environments and profile the victim.

10. Lateral Movement

Captured credentials and 2FA interception enable account takeover of banking and corporate applications. No direct network lateral movement, but compromised credentials create downstream lateral movement opportunities.

11. Command & Control (C2)

SpyNote uses a custom TCP-based C2 protocol over configurable ports. The builder tool generates APKs with hardcoded C2 server addresses. More recent variants implement C2 obfuscation and dynamic resolution. Communication is typically over non-standard ports to avoid signature detection.

12. Exfiltration

Exfiltrates captured keystrokes, screenshots, audio/video recordings, files, contacts, SMS, and location data to the C2 server. Keylogger logs stored locally in files named config[date].log before transmission.

13. Impact Analysis

Complete device compromise: full surveillance capability (audio/video/location), credential theft from banking and crypto apps, resistance to removal via accessibility and device admin abuse. APT usage (OilRig/APT34) elevates risk to high-value targets including government personnel and financial sector employees.

14. Indicators of Compromise (IOCs)

- APK files: meet.apk, Zoom02.apk, install.apk disguised as video conferencing apps
- Fake domains: us06webzoomus[.]pro and similar typosquatted meeting service URLs
- C2 communication on non-standard TCP ports (commonly 42474 in analyzed samples)
- Detection names: SpyNote, SpyMax, CypherRAT, CraxsRAT (various AV vendors)
- Accessibility Service registration in AndroidManifest.xml for non-accessibility apps
- Files: config[dd-MM-yyyy].log on external storage (keylogger output)
- Package names impersonating: com.avast.android.mobilesecurity, com.google.android.*, com.zoom.us

15. Detection & Mitigation

- Block APK sideloading via MDM; enforce Google Play Protect scanning.
- Monitor for Accessibility Service grants to non-standard applications — alert immediately.
- Implement network monitoring for outbound C2 traffic on non-standard TCP ports.
- Use mobile EDR solutions (Lookout, Zimperium, CrowdStrike Falcon for Mobile) with SpyNote signatures.
- Educate users: do not install APKs from SMS/WhatsApp links, fake app store sites, or video conferencing invitation links.
- For APT-targeted organizations: treat all mobile devices as potential surveillance vectors; enforce strict MDM policy.
- Keylogger artifact detection: monitor for config[date].log files in /sdcard/ path.

16. References & Sources

- MITRE ATT&CK – S0305 SpyNote RAT: <https://attack.mitre.org/software/S0305/>

- Zscaler ThreatLabz (2017): SpyNote RAT posing as Netflix app.
- Zscaler ThreatLabz (2024): Android and Windows RATs Distributed Through Online Meeting Lures.
- CYFIRMA Research: SpyNote – Unmasking a Sophisticated Android Malware.
- bczyz1 Research Blog (2020): An In-Depth Analysis of SpyNote Remote Access Trojan.
- ANY.RUN Malware Trends: SpyNote Analysis.
- Anomali Cyber Watch (2023): SpyNote source code publication and adoption surge.

Software Entry 7 of 10 — S0306: Trojan-SMS.AndroidOS.FakeInst.al

1. Name & Type / Basic Information

ATT&CK ID	S0306
Type	Malware – Android SMS Trojan
Platform	Android (Mobile)
First Seen	2013 (Kaspersky Mobile Malware Evolution 2013 report)
Last Modified (MITRE)	25 April 2025
Threat Actor	Financially motivated cybercriminals; primarily targeting Russian-speaking users
Associated Names	FakeInst, Trojan-SMS.FakeInst, Android.FakeInst

2. Description

Trojan-SMS.AndroidOS.FakeInst.a is an Android SMS Trojan documented in Kaspersky's Mobile Malware Evolution 2013 report as one of the most prevalent SMS Trojans of that period. FakeInst masquerades as an installer application for popular apps or services, tricking users into granting it permission to send premium-rate SMS messages. Its C2 communication uses Google Cloud Messaging (GCM) — now Firebase Cloud Messaging — which allows the attacker to deliver commands through Google's legitimate push notification infrastructure, bypassing traditional C2 detection.

3. ATT&CK Techniques Used

Technique ID	Tactic	Name	Description/Use
T1437.001	Command & Control	Application Layer Protocol: Web Protocols	Uses Google Cloud Messaging (GCM) for command delivery from attacker to infected device.
T1582	Impact	SMS Control	Sends premium-rate SMS messages to generate fraudulent charges.
T1643	Impact	Generate Traffic from Victim	Generates premium-rate SMS traffic for financial gain.

4. Execution Method

FakeInst is distributed as a fake installer APK, typically claiming to install a popular application, game, or adult content. It is distributed through third-party app stores and malicious websites. Upon installation, it immediately begins sending SMS to premium-rate numbers.

5. Persistence Techniques

Uses Android BOOT_COMPLETED broadcast receiver to ensure premium SMS activity continues after device restart. May also register periodic alarms to trigger SMS sending at scheduled intervals.

6. Privilege Escalation

No privilege escalation required. Operates entirely within normal Android SMS permissions (SEND_SMS) which users grant at installation without awareness of the financial consequence.

7. Defense Evasion

Uses GCM (Google Cloud Messaging) as the C2 channel, meaning commands arrive via Google's infrastructure — a trusted service that is virtually never blocked. This provides significant evasion over traditional C2 channels.

8. Credential Access

FakeInst.a does not directly harvest credentials. Its primary objective is SMS fraud for financial gain rather than credential collection.

9. Discovery Techniques

No documented discovery techniques. The malware operates narrowly for SMS fraud purposes.

10. Lateral Movement

No lateral movement capability. The malware is focused on financial fraud via premium-rate SMS.

11. Command & Control (C2)

Command and control is implemented via Google Cloud Messaging (GCM) — the attacker sends push notification commands to the infected device through Google's servers (T1437.001). This channel is effectively impossible to block at the network level without disrupting all GCM services.

12. Exfiltration

Minimal exfiltration — primarily sends SMS confirmation data back to C2. Focuses on outbound premium SMS generation rather than data theft.

13. Impact Analysis

Direct financial impact: victims receive unexpected charges on their mobile phone bills from premium-rate SMS messages sent without consent. At scale (botnet of infected devices), this generates significant illicit revenue for the attacker.

14. Indicators of Compromise (IOCs)

- APK disguised as fake installer for popular apps (com.install.*, com.fake.installer.*)
- SEND_SMS permission requested by installer-type apps
- GCM registration ID in app communications — outbound GCM traffic at unusual frequency
- Detection: Trojan-SMS.AndroidOS.FakeInst.a (Kaspersky), Android.FakeInst (various AV

vendors)

- Unexpected premium-rate SMS charges on victim's mobile bill
- Third-party app store distribution (not present on Google Play)

15. Detection & Mitigation

- Block third-party APK sideloading via MDM policy.
- Monitor mobile bills for unexpected premium-rate SMS charges.
- Deploy mobile AV with SMS Trojan detection capability.
- Review SEND_SMS permission grants: any non-messaging app requesting this permission should be treated with high suspicion.
- Network monitoring: unusual frequency of GCM communications from non-messaging apps.
- Apply MITRE Mobile mitigations M1011 (User Guidance) and M1006 (Use Recent OS Version).

16. References & Sources

- MITRE ATT&CK – S0306 Trojan-SMS.AndroidOS.FakeInst.a:
<https://attack.mitre.org/software/S0306/>
- Roman Unuchek and Victor Chebyshev, Kaspersky (2014): Mobile Malware Evolution: 2013. Securelist.

Software Entry 8 of 10 — S0307: Trojan-SMS.AndroidOS.Agent.aol

1. Name & Type / Basic Information

ATT&CK ID	S0307
Type	Malware – Android SMS Trojan
Platform	Android (Mobile)
First Seen	2013 (Kaspersky Mobile Malware Evolution 2013 report)
Last Modified (MITRE)	25 April 2025
Threat Actor	Financially motivated cybercriminals; targeting Russian and Eastern European mobile users
Associated Names	Trojan-SMS.Agent.ao, Android.Agent.ao

2. Description

Trojan-SMS.AndroidOS.Agent.ao is an Android SMS Trojan documented in Kaspersky's Mobile Malware Evolution 2013 report as part of the Agent family of mobile SMS Trojans. Like FakeInst.a and OpFake.a, Agent.ao uses Google Cloud Messaging (GCM) for its C2 channel, receiving commands from the attacker via Google's push notification infrastructure. Its primary function is sending premium-rate SMS messages from infected devices to generate fraudulent revenue. The Agent family represents one of the most prolific categories of Android malware in terms of volume, with hundreds of variants identified.

3. ATT&CK Techniques Used

Technique ID	Tactic	Name	Description/Use
T1437.001	Command & Control	Application Layer Protocol: Web Protocols	Uses Google Cloud Messaging (GCM) for attacker command delivery.
T1582	Impact	SMS Control	Sends premium-rate SMS messages without user consent.
T1643	Impact	Generate Traffic from Victim	Generates premium-rate SMS traffic for financial gain.

4. Execution Method

Agent.ao is delivered via third-party app stores, malicious SMS/links, and fake application websites. It typically poses as a legitimate utility or entertainment app. Upon installation, it registers with GCM and begins executing SMS fraud commands as directed by the C2.

5. Persistence Techniques

Registers Android broadcast receiver for BOOT_COMPLETED to maintain SMS fraud activity after device restart. May use AlarmManager to schedule periodic premium SMS sending.

6. Privilege Escalation

No privilege escalation required. Relies entirely on SEND_SMS permission granted at install time.

7. Defense Evasion

Uses GCM (Google Cloud Messaging / Google infrastructure) as C2 channel — effectively indistinguishable from legitimate push notification traffic at the network level. Disguises itself as a utility application.

8. Credential Access

No credential access capability documented for this specific variant. Focus is exclusively on premium SMS fraud.

9. Discovery Techniques

No documented discovery techniques. Narrow focus on SMS fraud with minimal device footprint.

10. Lateral Movement

No lateral movement capability.

11. Command & Control (C2)

C2 via Google Cloud Messaging (GCM). The attacker registers a GCM sender ID and pushes encoded commands to infected devices. Devices respond by sending premium SMS to attacker-controlled premium numbers. GCM-based C2 provides resilience and near-impossibility of network-layer blocking.

12. Exfiltration

Minimal: sends delivery confirmations of premium SMS to C2. Does not engage in broad data exfiltration.

13. Impact Analysis

Financial fraud: victims incur unexpected premium SMS charges. At botnet scale, thousands of infected devices collectively generate significant revenue for the criminal operator. The GCM-based C2 makes this infrastructure highly resilient to takedown.

14. Indicators of Compromise (IOCs)

- APK requesting SEND_SMS permission posing as utility/entertainment app
- GCM registration ID communications from non-messaging background processes
- Detection: Trojan-SMS.AndroidOS.Agent.ao (Kaspersky), SMS Trojan signatures
- Unexpected premium-rate SMS charges on mobile bill
- Distribution via non-official third-party app stores
- Anomalous periodic SMS sending behavior (non-user-initiated SMS dispatch)

15. Detection & Mitigation

- Enforce no-sideload policy via MDM; install only from Google Play.

- Flag SEND_SMS permission requests from non-messaging apps during installation review.
- Monitor mobile bills monthly for unrecognized premium-rate charges.
- Mobile AV: Kaspersky Mobile, Dr.Web, ESET Mobile Security all have Agent family signatures.
- Android 4.2+ provides a built-in warning before apps can send premium SMS — ensure OS is updated.
- Apply MITRE Mobile mitigation M1011 (User Guidance) and M1006 (Use Recent OS Version).

16. References & Sources

- MITRE ATT&CK – S0307 Trojan-SMS.AndroidOS.Agent.ao:
<https://attack.mitre.org/software/S0307/>
- Roman Unuchek and Victor Chebyshev, Kaspersky (2014): Mobile Malware Evolution: 2013. Securelist.

Software Entry 9 of 10 — S0308: Trojan-SMS.AndroidOS.OpFake.al

1. Name & Type / Basic Information

ATT&CK ID	S0308
Type	Malware – Android SMS Trojan
Platform	Android (Mobile)
First Seen	2013 (Kaspersky Mobile Malware Evolution 2013 report)
Last Modified (MITRE)	25 April 2025
Threat Actor	Financially motivated cybercriminals; initially impersonated Opera browser to target global users
Associated Names	OpFake, Opera Fake, Android.OpFake

2. Description

Trojan-SMS.AndroidOS.OpFake.a is an Android SMS Trojan that derives its name from its original distribution method: masquerading as the Opera browser for Android. Documented in Kaspersky's Mobile Malware Evolution 2013 report, OpFake.a belongs to the same GCM-based SMS Trojan family as FakeInst.a and Agent.ao. It conducts premium-rate SMS fraud by sending unauthorized messages to premium numbers, controlled via Google Cloud Messaging. OpFake was one of the most prevalent Android malware families of 2012-2013 and was distributed across multiple platforms beyond just Opera impersonation.

3. ATT&CK Techniques Used

Technique ID	Tactic	Name	Description/Use
T1437.001	Command & Control	Application Layer Protocol: Web Protocols	Uses Google Cloud Messaging (GCM) for C2 and command delivery.
T1582	Impact	SMS Control	Sends unauthorized premium-rate SMS messages.
T1655.001	Defense Evasion	Masquerading: Match Legitimate Name	Originally impersonated the Opera browser for Android to deceive users.

4. Execution Method

OpFake.a is distributed as a fake Opera browser APK or other masqueraded applications via third-party stores and malicious websites. Users believing they are installing the Opera browser install the Trojan instead. Upon execution, it connects to GCM and awaits SMS fraud commands.

5. Persistence Techniques

BOOT_COMPLETED broadcast receiver ensures the malware activates on device restart. GCM registration maintains a persistent attacker-controlled communication channel.

6. Privilege Escalation

No privilege escalation required. Operates within SEND_SMS permission granted at install.

7. Defense Evasion

Masquerades as a legitimate, well-known application (Opera browser) to deceive users (T1655.001). Uses GCM C2 channel to evade network detection. Presence on device may go unnoticed as user may believe they successfully installed Opera.

8. Credential Access

No credential harvesting documented. Focus is on premium SMS fraud.

9. Discovery Techniques

No documented discovery techniques.

10. Lateral Movement

No lateral movement capability.

11. Command & Control (C2)

GCM (Google Cloud Messaging) based C2 — identical architecture to FakeInst.a and Agent.ao. Commands are push-delivered from attacker to infected devices via Google infrastructure.

12. Exfiltration

Minimal: sends SMS delivery confirmations. No broad data exfiltration.

13. Impact Analysis

Premium SMS fraud resulting in unauthorized charges on victim's mobile account. Historical prevalence was extremely high — OpFake was among the top Android malware families by volume in 2012-2013. Masquerading as a legitimate popular browser lowered user suspicion and increased infection rates.

14. Indicators of Compromise (IOCs)

- APK named Opera.apk or similar Opera-browser impersonating filenames
- Package names: com.opera.browser.fake.* or similar deceptive package names
- GCM communications from an app claiming to be Opera but behaving as background SMS service
- Detection: Trojan-SMS.AndroidOS.OpFake.a (Kaspersky), Android.OpFake (various vendors)

- Unexpected premium SMS charges on mobile bill
- App icon matching Opera browser but from unofficial source

15. Detection & Mitigation

- Always install Opera and other browsers exclusively from Google Play — verify publisher.
- Block APK sideloading via MDM policy.
- Mobile AV (Kaspersky Mobile, ESET, Avast) with OpFake family signatures.
- Monitor for SEND_SMS activity from apps claiming to be browsers — browsers should never send SMS.
- Android 4.2+ OS built-in premium SMS warnings help prevent unauthorized charges.
- Apply MITRE Mobile mitigations M1011 (User Guidance) and M1006 (Use Recent OS Version).

16. References & Sources

- MITRE ATT&CK – S0308 Trojan-SMS.AndroidOS.OpFake.a:
<https://attack.mitre.org/software/S0308/>
- Roman Unuchek and Victor Chebyshev, Kaspersky (2014): Mobile Malware Evolution: 2013. Securelist.

Software Entry 10 of 10 — S0309: Adups

1. Name & Type / Basic Information

ATT&CK ID	S0309
Type	Malware – Android Pre-installed Spyware / Supply Chain Compromise
Platform	Android (Mobile)
First Seen	November 2016 (publicly disclosed)
Last Modified (MITRE)	25 April 2025

Threat Actor	Shanghai Adups Technology Co., Ltd. – Chinese company; suspected Chinese government-related data collection
Associated Names	Adups FOTA, BLU Spyware, Firmware OTA Spyware

2. Description

Adups is pre-installed firmware-level spyware that was discovered by Kryptowire researchers and reported by the New York Times in November 2016. Adups was built into the firmware of Android devices manufactured by BLU Products and other vendors, where it was ostensibly installed as a Firmware Over-The-Air (FOTA) update service by Shanghai Adups Technology Co., Ltd. — a Chinese company. In practice, the software secretly transmitted device data including SMS messages, call logs, contact lists, and GPS location to Chinese servers every 72 hours. This represents a supply chain compromise (T1474.003) — malware embedded at the manufacturing level before devices reach end users.

3. ATT&CK Techniques Used

Technique ID	Tactic	Name	Description
T1430	Collection	Location Tracking	Transmitted GPS location information to Chinese servers.
T1636.002	Collection	Protected User Data: Call Log	Transmitted full call logs from the device.
T1636.003	Collection	Protected User Data: Contact List	Transmitted full contact lists to remote servers.

T1636.004	Collection	Protected User Data: SMS Messages	Transmitted the full contents of all SMS messages.
T1474.003	Initial Access	Supply Chain Compromise: Software Supply Chain	Pre-installed on Android devices at manufacturing level, shipped to consumers embedded in firmware.

4. Execution Method

Adups required no user action — it was pre-installed as a system-level application in device firmware. It ran automatically as a background service with elevated system privileges, transmitted data silently without user consent, and could not be uninstalled through normal Android app management as it was a system app.

5. Persistence Techniques

Persistence is guaranteed by design — Adups is embedded in the device firmware as a system application, making it persistent across factory resets. It survives all normal user-initiated removal attempts. Removal requires reflashing the device firmware.

6. Privilege Escalation

Adups operates with system-level privileges by virtue of being a pre-installed firmware component — the highest level of Android privilege available. No escalation required; privileges are baked in at manufacturing.

7. Defense Evasion

Primary evasion: presence as a legitimate-looking system update service (FOTA — Firmware Over-The-Air). System applications are not visible or removable through normal Android settings. Running as a background system service with no visible UI makes it invisible to users. Data transmission is disguised as routine firmware update activity.

8. Credential Access

Adups collects SMS messages which may contain 2FA codes, OTPs, and credential-recovery messages. Contact lists and call logs provide relationship mapping valuable for social engineering and targeted attacks.

9. Discovery Techniques

Adups collects comprehensive device metadata including phone number, IMEI, device model — enabling the Chinese servers to build detailed device and user profiles.

10. Lateral Movement

No lateral movement capability from the device itself. However, collected data (contact lists, SMS, location) could be used to identify and target additional individuals connected to the device owner.

11. Command & Control (C2)

Adups transmitted collected data to servers operated by Shanghai Adups Technology, located in China. Data transmission occurred at 72-hour intervals. The C2 is the Adups corporate infrastructure — making blocking difficult as it masquerades as legitimate firmware update traffic.

12. Exfiltration

Systematic exfiltration of: full SMS message content, call logs, contact lists, and GPS location data — transmitted to Chinese servers every 72 hours. The scope of exfiltration (full SMS body content) goes far beyond any legitimate FOTA requirement.

13. Impact Analysis

Mass privacy violation affecting hundreds of thousands of BLU Products device owners and users of other affected manufacturers. The supply chain attack vector means victims have no means of protection short of not purchasing the affected hardware. Potential Chinese government intelligence collection from US consumers. Resulted in FTC investigation and settlements. Adups later agreed to reduce data collection, but the episode highlighted severe risks from firmware-level supply chain compromise.

14. Indicators of Compromise (IOCs)

- Device manufacturer: BLU Products devices (R1 HD, Energy X Plus 2, Neo XL, Energy Diamond Mini, Advance 4.0 L2 and others)
- System APK: com.adups.fota (Firmware OTA Update service)
- Outbound network connections every 72 hours to Adups servers: bigdata.adups[.]com, adupstech[.]com
- System processes: AdupsFota, AdupsService running as persistent background services
- Detection: classified as potentially unwanted program (PUP) or spyware by major AV vendors after disclosure
- Kryptowire analysis (2016): SHA256 hashes and network IOCs documented in original research report

15. Detection & Mitigation

- Verify firmware integrity of Android devices before deployment in enterprise environments.
- Use Android Enterprise/MDM to inventory pre-installed system applications on corporate devices.
- Monitor network traffic from mobile devices for periodic connections to Adups infrastructure (bigdata.adups[.]com).
- Prefer devices with Android One or stock Android firmware from verified manufacturers.
- Conduct supply chain risk assessment before procuring Android devices for sensitive use cases.
- Apply MITRE Mobile mitigation M1013 (Application Developer Guidance) and M1005 (Pre-OS Boot / Supply Chain).
- For high-risk environments: use hardware with verified open-source firmware (e.g., Google Pixel with GrapheneOS).

16. References & Sources

- MITRE ATT&CK – S0309 Adups: <https://attack.mitre.org/software/S0309/>
- Matt Apuzzo and Michael S. Schmidt, New York Times (2016): Secret Back Door in Some U.S. Phones Sent Data to China
- Jeremy Kirk, BankInfoSecurity (2016): Why Did Chinese Spyware Linger in U.S. Phones?
- Kryptowire (2016): Original Technical Disclosure of Adups Spyware.
- FTC Investigation into BLU Products and Adups (2017-2018).

Summary & Conclusion

This report documents all 10 assigned software entries (S0300–S0309) for Intern ID 2130 as part of the MITRE ATT&CK Research Internship Group Leader Selection Program. All 10 entries belong to the MITRE ATT&CK Mobile domain and represent Android-platform malware spanning the period 2013–2025.

Key analytical observations across the software range:

- All 10 entries target the Android mobile platform, reflecting a cohesive threat theme of mobile-focused adversary tooling.
- Three entries (S0306, S0307, S0308) share an identical GCM-based C2 architecture and premium SMS fraud objective, representing an SMS Trojan family cluster documented in Kaspersky's Mobile Malware Evolution 2013.
- S0301 (Dendroid) and S0305 (SpyNote RAT) represent the most feature-rich RAT tools, with SpyNote continuing to evolve and be used by APT groups through 2025.
- S0309 (Adups) is the most strategically significant entry, representing a firmware-level supply chain compromise with nation-state-level implications.

- S0300 (DressCode) poses the greatest enterprise network risk due to its SOCKS tunneling capability in BYOD environments.
- S0304 (Android/Chuli.A) is the only entry with clear APT/nation-state targeting of human rights activists, carrying significant human rights implications beyond typical cybersecurity risk.